MCP SECURITY RELEASE V2.1.0

8 bugs fixed in the official MCP servers. npm will not install the patch.

Filesystem, Fetch and Everything reference servers

Released 25 Oct 2026

8 slides - save for your next MCP server review

 Jatin Mishra

ONE RELEASE

8

Security bugs fixed in the reference servers

4 in Filesystem, 3 in Fetch, 1 in Everything

8 external reporters credited

 Jatin Mishra

Why npm says there is nothing to update

Old versions were dates: 2026.8.31

The patched version is 2.0.1

npm sorts 2.0.1 lower, so npm update and Dependabot report nothing. Install 2.0.1 by hand.

WHAT BROKE

3 of the 4 filesystem bugs are plain path checks

A symlink name in a different case passed the symlink check

A trailing quote or space in the path passed the folder check

A check-then-write race (TOCTOU) wrote outside allowed folders

A prompt-injected model can now trigger these with one tool call

Old bug classes, new trigger: an AI agent reads attacker text, then calls write_file.

The Everything server also skipped the Origin check the MCP spec says servers MUST do.

CHECKLIST

5 path and URL checks every MCP tool needs

1. Resolve the real path after every hop
2. Match case the way the disk does
3. Check the same string you open
4. Resolve redirects and private addresses before fetching
5. Never set Access-Control-Allow-Origin: * locally

RECAP

Three things to do this week

Patch: Install server-filesystem 2.0.1 by hand; npm will not offer it

Forks: Audit private forks for the same 4 bug classes

Checks: Run the 5 path and URL checks on every tool

Which version are your forks on?

Full release notes and advisory links are in the first comment.

Save this for your next MCP server review